TECHCRUSH

Cybersecurity Track – Cohort 8 Capstone Project

PROJECT 2

Developing Incident Response Playbooks

Phishing • Ransomware • DDoS • Post-Incident Review

Incident Response Playbooks, NIST IR Lifecycle, Communication & Metrics

GROUP 18

Cohort 8

Playbooks: Phishing, Ransomware and DDoS, with a Post-Incident Review Template

Group members are listed on the next page.

Group 18 – Project Members

Members who performed the project:

No.	Name	Registration Number
1.	Victoria Oladehinde	CYBE/2026/TC-8/0461
2.	Solomon Ogheneochuko David	CYBE/2026/TC-8/0242
3.	Oriji Kelvin Promise	CYBE/2026/TC-8/0570
4.	Emmanuel Eguzoroh	CYBE/2026/TC-8/0060
5.	Morgan Ekezie	CYBE/2026/TC-8/0140
6.	Amos Adetunlese	CYBE/2026/TC-8/0037
7.	Benjamin Okon Udoh	CYBE/2026/TC-8/0230
8.	Olayinka Aramide Oyinkansola	CYBE/2026/TC-8/0561
9.	Shiaka Paul Woncin	CYBE/2026/TC-8/0536
10.	Adekitan Oluwatunmise E.E	CYBE/2026/TC-8/0255
11.	Anuoluwapo Alabi	CYBE/2026/TC-8/0446
12.	Iyangbe Joshua	CYBE/2026/TC-8/0221
13.	Theresa Nnenna Ndukwe	CYBE/2026/TC-8/0158
14.	Kelvin Enow	CYBE/2026/TC-8/0211
15.	Adewuyi Esther	CYBE/2026/TC-8/0749

Contents

Project 2 – Group 18 Members

Group 18 – Project Members 2

Incident Response Playbooks Report

Executive Summary 4

1. Introduction and Scope 4

2. Playbook 1: Phishing Attack Response 5

3. Playbook 2: Ransomware Infection Response 7

4. Playbook 3: DDoS Attack Response 9

5. Design Choices and Expected Benefits 11

6. Post-Incident Review Template 12

7. Appendix – Roles and Communication Matrix 15

Executive Summary

This report presents three comprehensive Incident Response (IR) Playbooks developed for common cybersecurity incidents: phishing attacks, ransomware infections, and Distributed Denial-of-Service (DDoS) attacks. Each playbook follows the standard IR lifecycle of Detection, Containment, Eradication and Recovery, and includes clear roles, communication guidance and measurable success metrics.

The playbooks are designed to be practical and immediately usable by an organisational IR team. A completed Post-Incident Review Template is also provided to demonstrate how lessons learned can be captured and turned into concrete improvements.

Project Evidence Strategy

- Each playbook begins with identification triggers and indicators of compromise.
- Response phases are presented in tables showing actions, owners and time targets.
- Roles, communication strategy and success metrics are defined for every scenario.
- Design choices and organisational benefits are explained in a dedicated section.
- A fully completed post-incident review sample shows how the template is used in practice.

1. Introduction and Scope

Objective

This project focuses on designing comprehensive Incident Response (IR) Playbooks for handling different types of cybersecurity incidents. The goal is to create structured, actionable plans that organisations can use to manage and respond to security threats effectively, minimise damage, and ensure quick recovery.

Scope

Three playbooks were developed covering phishing attacks, ransomware infections, and Distributed Denial of Service (DDoS) attacks. Each playbook outlines clear steps for detection, containment, eradication and recovery, while also defining roles, communication plans, and metrics for measuring success.

The structure follows industry best practices from NIST SP 800-61 and the SANS Incident Handler’s Handbook, while remaining practical for operational teams.

How to Use These Playbooks

- Before an incident: Customise contact lists, tools and escalation paths to match the organisation’s environment.
- During an incident: Follow the phases in order and use the roles section to assign ownership quickly.
- After an incident: Complete the Post-Incident Review Template to capture lessons learned and drive improvements.

2. Playbook 1: Phishing Attack Response

Phishing remains one of the most common initial access vectors. This playbook provides a structured response for email-based phishing, spear-phishing and business email compromise (BEC) scenarios.

2.1 Incident Identification – Triggers and Indicators

Triggers / Detection Sources

- User reports of suspicious emails (via security awareness button or helpdesk)
- Email security gateway alerts (high-risk scores, newly observed domains, spoofing indicators)
- SIEM / UEBA alerts for anomalous login attempts following email opens
- Endpoint detection of credential harvesting pages or malware droppers
- Multiple users reporting similar messages within a short time window

Key Indicators of Compromise (IOCs)

- Suspicious sender domains or display-name spoofing
- Urgency language, unexpected attachments or credential-harvesting links
- Look-alike domains (typosquatting)
- Unusual outbound traffic or authentication failures after email interaction
- Presence of known malicious hashes or URLs in email body/attachments

2.2 Incident Response Phases

Phase	Key Actions	Owner	Time Target
Detection	Validate report or alert. Quarantine email. Extract IOCs. Search organisation-wide. Confirm if credentials were submitted.	SOC Analyst / IR Lead	≤ 30 min
Containment	Block sender domain/IP and malicious URLs. Force password reset for compromised accounts. Isolate affected endpoints.	Email Security + Identity	≤ 1 hour
Eradication	Remove malicious emails from all mailboxes. Delete malware. Revoke sessions/tokens. Patch related vulnerabilities.	IR Technical Lead + Endpoint	≤ 4 hours
Recovery	Restore normal email flow. Re-enable accounts after verification. Monitor for re-compromise. Update detection rules.	IR Lead + Communications	≤ 24 hours

2.3 Roles and Responsibilities

- Incident Commander: Overall coordination, escalation decisions, executive updates.
- Technical Lead (IR): Directs technical investigation, containment and eradication.
- SOC Analyst: Initial triage, IOC extraction, mailbox searches, alert correlation.
- Email / Messaging Team: Gateway blocks, message purges, policy updates.

- Identity & Access Management: Password resets, MFA enforcement, session revocation.
- Communications Lead: Internal user notifications and external reporting if required.
- Legal / Compliance: Advises on regulatory notification obligations.

2.4 Communication Strategy

- Internal: Immediate notification to IR team via dedicated channel. Status updates every 30–60 minutes during active response.
- Affected Users: Clear instructions on password changes and how to report further suspicious activity.
- External: Notify email provider / threat intel partners if widespread. Report to authorities only if required by policy or regulation.
- Executives: Concise situation reports focusing on impact, containment status and residual risk.

2.5 Success Metrics

- Time to Detect: ≤ 15 minutes from first malicious email delivery to alert/report.
- Time to Contain: Malicious sender/URLs blocked and accounts secured ≤ 1 hour from confirmation.
- Scope Containment: ≥ 95% of similar emails purged organisation-wide within 2 hours.
- Credential Impact: Zero lateral movement or secondary compromise.
- User Awareness: Post-incident phishing simulation click-rate reduction of ≥ 20% within 30 days.

3. Playbook 2: Ransomware Infection Response

Ransomware incidents require rapid containment to prevent encryption spread, careful evidence preservation, and disciplined recovery from clean backups. Paying the ransom is not the preferred recovery strategy.

3.1 Incident Identification – Triggers and Indicators

Triggers / Detection Sources

- EDR alerts for mass file encryption, ransomware notes or known ransomware processes
- User reports of inaccessible files or ransom notes on the desktop
- SIEM alerts for anomalous file-write activity, shadow copy deletion or privilege escalation
- Backup system alerts indicating failure or unusual access patterns
- Network detection of C2 traffic associated with known ransomware families

Key Indicators of Compromise (IOCs)

- Presence of ransom notes (README.txt, HTML payment instructions)
- Mass file renaming with ransomware-specific extensions
- Deletion or encryption of Volume Shadow Copies / backup catalogues
- Unusual outbound connections to TOR or known ransomware infrastructure
- Known ransomware binaries or living-off-the-land techniques for lateral movement

3.2 Incident Response Phases

Phase	Key Actions	Owner	Time Target
Detection	Confirm ransomware activity. Identify patient-zero system(s). Identify family if possible. Preserve evidence where safe.	SOC / IR Lead	≤ 15 min
Containment	Isolate affected systems immediately. Disable compromised accounts. Block C2. Pause risky backup jobs. Avoid powering off unless necessary.	IR Technical Lead + Network	≤ 30 min
Eradication	Remove all ransomware binaries, persistence and backdoors. Rebuild or cleanse systems from known-good media. Confirm no residual access.	IR + Endpoint + Identity	Hours–Days
Recovery	Restore from verified clean backups (offline/immutable preferred). Validate integrity. Reintroduce systems with enhanced monitoring.	IT Ops + IR Lead	Per RTO targets

3.3 Roles and Responsibilities

- Incident Commander: Strategic decisions (including ransom policy), external coordination, executive briefing.

- Technical Lead: Directs isolation, eradication and recovery workstreams.
- Endpoint / EDR Team: Host isolation, malware analysis, system rebuilds.
- Network Team: Segmentation, C2 blocking, traffic analysis.
- Backup & Recovery Team: Backup integrity assessment, restoration prioritisation, validation.
- Threat Intelligence: Ransomware family identification and decryption resource checks.
- Legal / Compliance / Cyber Insurance: Notification obligations and insurer engagement.
- Communications: Internal and external messaging, media handling if required.

3.4 Communication Strategy

- Internal Crisis Channel: Activate dedicated IR bridge immediately. Regular situation reports.
- Executive Leadership: Early briefing on business impact, estimated downtime and decision points.
- Employees: Transparent messaging on what happened, what not to do, and how to report issues.
- External: Coordinate with Legal before any public statement. Engage law enforcement early if significant impact. Notify cyber insurance per policy.

3.5 Success Metrics

- Time to Isolate: Affected systems isolated ≤ 30 minutes from confirmed detection.
- Encryption Spread: Zero additional systems encrypted after initial detection (ideal).
- Backup Integrity: ≥ 95% of critical systems restorable from clean, recent backups.
- Recovery Time Objective (RTO): Critical systems restored within defined organisational RTO.
- No Ransom Payment: Preference for recovery without payment; any payment consideration fully documented.

4. Playbook 3: Distributed Denial-of-Service (DDoS) Attack Response

DDoS attacks aim to disrupt service availability. Effective response requires rapid detection, traffic filtering (often via upstream providers or cloud scrubbing), and clear stakeholder communication while preserving forensic data where possible.

4.1 Incident Identification – Triggers and Indicators

Triggers / Detection Sources

- Network performance / APM alerts showing sudden latency spikes, high error rates or unavailability
- Firewall / WAF / load-balancer alerts for abnormal traffic volumes or connection rates
- Upstream ISP or DDoS protection provider notifications
- User or customer reports of inability to access services
- SIEM correlation of volumetric spikes across multiple sensors

Key Indicators

- Sudden, sustained increase in inbound traffic (volumetric) or connection attempts (protocol / application-layer)
- Traffic from unusual geographic distributions or known botnet source ranges
- Specific attack signatures (SYN floods, UDP amplification, HTTP floods, Slowloris-style)
- Legitimate traffic being crowded out; elevated packet loss or latency
- Concurrent application-layer anomalies if the attack is multi-vector

4.2 Incident Response Phases

Phase	Key Actions	Owner	Time Target
Detection	Confirm degradation is attack-related. Classify attack type. Estimate impact. Notify DDoS mitigation provider if under contract.	NOC / SOC Analyst	≤ 10 min
Containment	Activate mitigation (cloud scrubbing, on-prem filtering, ISP blackholing). Apply rate-limiting / geo-blocking. Preserve flow logs and captures.	Network / Security Engineering	≤ 15–30 min
Eradication	Continue refined filtering until attack ends. Work with upstream providers. Analyse patterns for future detection improvements.	Network + Threat Intel	Duration of attack
Recovery	Gradually remove emergency filters. Validate full service restoration. Review capacity and architecture. Update runbooks and thresholds.	Network Ops + IR Lead	≤ 2 hours post-attack

4.3 Roles and Responsibilities

- Incident Commander: Overall coordination, service prioritisation, external communications decisions.
- Network Operations / NOC: Primary technical responders; activate mitigation and coordinate with ISP/provider.
- Security Operations (SOC): Confirm attack classification and assist with application-layer analysis.
- Application / Platform Owners: Assess business impact and support application-level mitigations.
- Communications Lead: Status page updates, customer notifications, internal awareness.
- Vendor / ISP Liaison: Escalation to upstream providers and managed DDoS services.
- Executive Sponsor: Informed of prolonged or high-impact outages.

4.4 Communication Strategy

- Internal: Immediate activation of IR / NOC bridge. Real-time updates during the attack. Summary within 1 hour of recovery.
- Customers / Public: Transparent status page updates. Avoid speculative language. Update frequency matched to severity.
- Executives: Concise impact assessment (services affected, customer impact, mitigation ETA).
- External Providers: Maintain open channel with DDoS vendor and ISP throughout the event.

4.5 Success Metrics

- Time to Detect: Service degradation recognised and classified as DDoS ≤ 10 minutes.
- Time to Mitigate: Effective filtering / scrubbing activated ≤ 15–30 minutes from confirmation.
- Service Availability: ≥ 95% of legitimate traffic delivered for critical services once mitigation is active.
- Mean Time to Recovery (MTTR): Full return to baseline ≤ 2 hours after attack ends.
- Post-Attack Improvement: Detection thresholds and playbook updates completed within 5 business days.

5. Design Choices and Expected Benefits

5.1 Design Philosophy

The playbooks were designed around the following principles:

- Actionable over theoretical – concrete steps and time targets create urgency and accountability.
- Role clarity – explicit ownership prevents diffusion of responsibility during high-stress incidents.
- Communication as a first-class concern – poor communication is a frequent failure mode in IR.
- Metrics-driven – success criteria defined up front enable objective evaluation and continuous improvement.
- Alignment with standards – structure follows the NIST incident response lifecycle while remaining practical.
- Scenario-specific nuance – common skeleton with emphasis on the unique priorities of each incident type.

5.2 Key Design Choices by Playbook

Phishing Playbook

Emphasis is placed on rapid IOC extraction and organisation-wide email purging because phishing campaigns often target many users simultaneously. Credential reset and session revocation are prioritised because account takeover is the most common downstream impact.

Ransomware Playbook

Isolation is the highest priority action because every additional encrypted system increases recovery cost and time. Restoration from clean backups is treated as the primary recovery path. Backup integrity assessment is explicitly called out because many organisations discover backup failures only during a real event.

DDoS Playbook

The playbook assumes pre-arranged relationships with upstream providers or cloud scrubbing services, as most organisations cannot absorb large volumetric attacks alone. Detection-to-mitigation time targets are aggressive because availability impact is immediate and customer-visible.

5.3 Expected Benefits for Organisational IR Readiness

- Reduced Mean Time to Respond (MTTR) through pre-defined actions and clear ownership.
- Consistent, repeatable responses that reduce reliance on tribal knowledge.
- Improved cross-team coordination between SOC, Network, Identity, Communications and Leadership.
- Measurable improvement cycle via built-in metrics and the Post-Incident Review Template.
- Regulatory and audit readiness through documented, practised procedures.
- Lower business impact from faster containment and recovery.
- Cultural reinforcement of a structured approach to security incidents.

These playbooks should be treated as living documents and reviewed at least annually, after every major incident, and whenever significant changes occur in the technology environment or threat landscape.

6. Post-Incident Review Template (Completed Sample)

The following is a fully completed example based on a realistic phishing incident. It demonstrates how the template should be used after a real event.

6.1 Incident Summary

Incident ID / Ticket	INC-2026-0918-PHISH-042
Incident Type	[X] Phishing [ ] Ransomware [ ] DDoS [ ] Other
Date/Time Detected	18 September 2026, 09:14 WAT
Date/Time Contained	18 September 2026, 10:02 WAT
Date/Time Fully Recovered	18 September 2026, 15:40 WAT
Severity	High
Incident Commander	Amina Okoro (CISO Office)
Technical Lead	David Mensah (SOC Lead)

6.2 Timeline of Key Events

1. 09:14 – User in Finance reported suspicious email via “Report Phish” button (Payroll credential-harvesting link).

2. 09:22 – SOC validated report, extracted IOCs and initiated organisation-wide search. 47 similar messages found.

3. 09:35 – Incident Commander activated. Gateway blocked sender and URL. Messages purged from all mailboxes.

4. 09:48–10:02 – Three users confirmed credential submission. Password resets and session revocation completed.

5. 11:15 – All-staff advisory sent. Enhanced monitoring enabled for 72 hours. No further compromise detected.

6. 15:40 – Incident formally closed after final IOC sweep.

6.3 Impact Assessment

- Systems / services affected: Corporate email (Microsoft 365); three Finance user accounts.
- Users impacted: 47 received the email; 3 submitted credentials; 0 customers affected.
- Data compromised: No confirmed exfiltration. Credential exposure limited to three accounts (reset immediately).
- Business / financial impact: Minimal – approximately 4 hours of SOC + IT effort. No downtime.
- Regulatory notification required? [ ] Yes [X] No.

6.4 What Went Well

- Rapid user reporting via dedicated button enabled detection within minutes.
- Organisation-wide purge completed in under 20 minutes.

- Clear role assignment allowed parallel workstreams without confusion.
- Existing gateway rules and SIEM correlation accelerated IOC confirmation.

6.5 What Did Not Go Well / Gaps Identified

- Three users still entered credentials despite prior awareness training.
- Initial gateway score was only “medium”; message was not auto-quarantined.
- Short delay locating Identity team contact for password-reset authority.
- No automated SOAR playbook trigger; all steps executed manually.

6.6 Root Cause Analysis

Primary root cause: Targeted spear-phishing using a look-alike domain and urgency language impersonating internal Payroll. The message bypassed initial automated filtering.

Contributing factors: (1) Users not consistently verifying sender domains; (2) Conservative gateway thresholds; (3) Lack of real-time URL rewriting / sandbox detonation for all external links.

6.7 Metrics vs. Targets

Metric	Target	Actual	Met?
Time to Detect	≤ 15 min	≈ 8 min	[X] Yes
Time to Contain	≤ 1 hour	48 minutes	[X] Yes
Time to Recover	≤ 24 hours	6 h 26 min	[X] Yes
Scope Contained	≥ 95% purged	100% (47/47)	[X] Yes
Credential Impact	0 lateral movement	0 (sessions revoked)	[X] Yes

6.8 Lessons Learned and Action Items

#	Action Item	Owner	Due Date	Priority
1	Lower gateway threshold for look-alike domains; auto-quarantine high-urgency payroll-themed messages	Email Security	30 Sep 2026	High
2	Deploy URL rewriting + sandbox detonation for all external email links	Security Engineering	15 Oct 2026	High
3	Update Identity escalation contacts and after-hours authority matrix	IR Lead / IAM	25 Sep 2026	Medium
4	Conduct focused phishing simulation for Finance and HR; track click rate	Security Awareness	09 Oct 2026	Medium
5	Create SOAR automation for initial phishing triage and bulk email purge	SOC Automation	31 Oct 2026	Medium

6.9 Playbook / Process Updates Required

- [X] Update detection rules / signatures
- [X] Revise playbook steps or time targets
- [X] Improve tooling or automation
- [X] Additional training or tabletop exercise needed
- [ ] Other: N/A

6.10 Sign-off

Incident Commander: Amina Okoro _____ Date: 22 September 2026

Technical Lead: David Mensah _____ Date: 22 September 2026

Review completed and actions tracked in: Jira Security Project – Epic SEC-1847

7. Appendix – Roles and Communication Matrix

Summary of primary responsibilities across the three playbooks. Customise contact details for the organisation.

Role	Phishing	Ransomware	DDoS
Incident Commander	Overall coordination	Strategic decisions, ransom policy	Service prioritisation
Technical / IR Lead	Investigation & containment	Isolation & eradication lead	Mitigation coordination
SOC Analyst	Triage, IOC extraction	Initial detection & scoping	Attack classification
Network Team	URL/domain blocking	Segmentation, C2 block	Primary mitigation owner
Identity Team	Password resets, session kill	Account disablement	Secondary (if relevant)
Endpoint Team	Malware removal	Rebuild / cleanse systems	Minimal direct role
Communications	User & exec updates	Crisis messaging	Status page & customer updates
Legal / Compliance	Breach assessment	Notification & insurance	SLA / regulatory check

End of Report. These playbooks should be customised with organisation-specific contacts, tools and escalation paths before operational use. Regular tabletop exercises are strongly recommended.